Transparency Upstream, Evidence Downstream

MANUFACTURERS AND OPEN SOURCE UNDER THE CRA

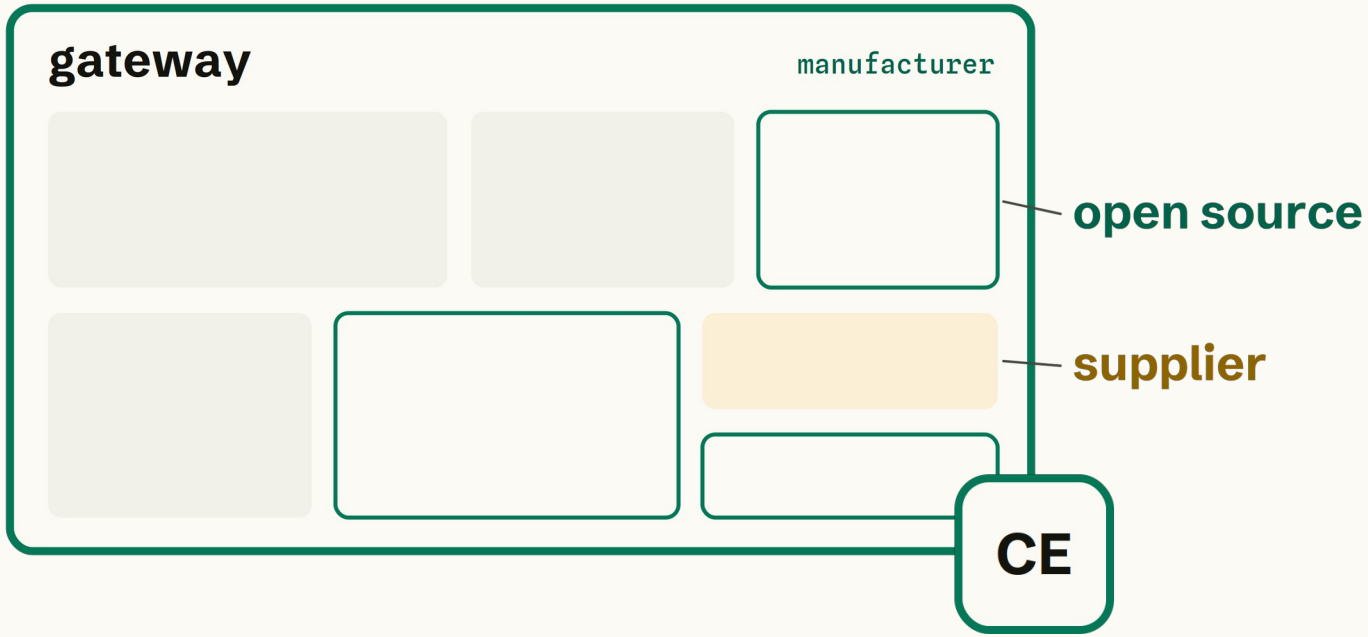
William Janssen

CTO & HEAD OF ENGINEERING · AUTHOR OF A BOOK ON THE EU CYBER RESILIENCE ACT · BUILDING THE OPERATIONAL SIDE OF CRA COMPLIANCE · EX-RED HAT & FOUNDER

CODE & COMPLIANCE 2026 · BRUSSELS · 27 OCTOBER 2026

Who carries the product

The manufacturer carries the product.

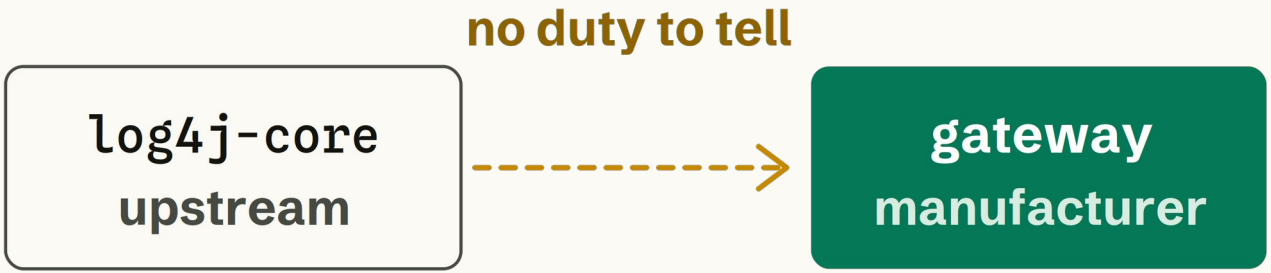


From December 2027: not another compliance rule. Market access.

08:14

08:14

Nobody told her. Nobody had to.



08:30



Three names. One question.

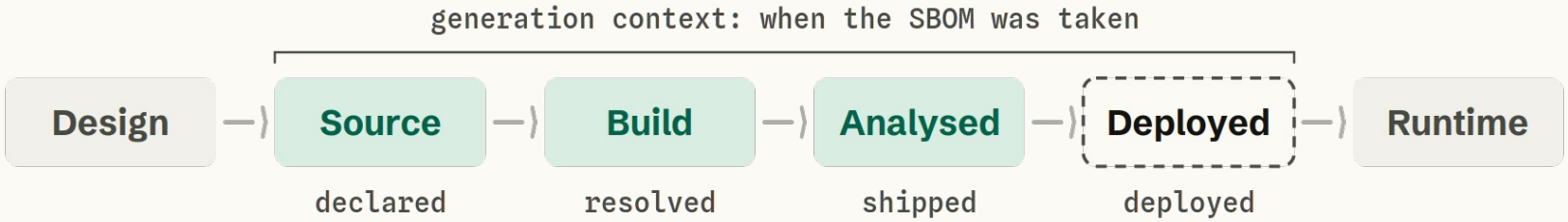
CPE	cpe:2.3:a:apache:log4j:2.12.1
purl	pkg:maven/org.apache.logging.log4j/log4j-core@2.12.1
hash	sha256:…



10:00



declared ≠ resolved ≠ shipped ≠ deployed





11:30



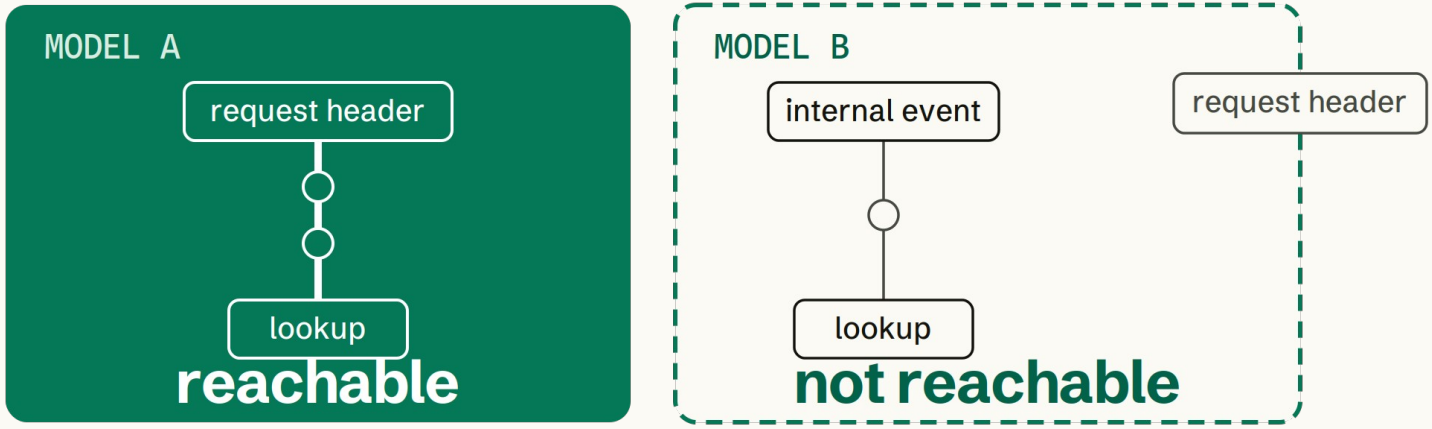
The clock has not started. The work has.



13:00

13:00

Same version. Same CVE. Different verdict.



14:00



Can we still build it?

2019 firmware, seven years on

source	still in the repo
compiler	moved on
CI image	retired
test rig · 2019 hardware	if it still boots
engineer	left in 2023

--(?)→ security update · 2026

owed by law for products placed from Dec 2027



PHP 7.4 · 8.0 · 8.1: backports only, "a last resort" · Oct 2026

15:00

15:00

Upstream shipped a fix.

Procurement wants a signature.

maintainer	steward (from Dec 2027)	manufacturer
publishes	sustains	signs
transparency	viability	assurance



funding, not warranties · contribution, not transferred responsibility

16:30



Awareness. The clock starts.



22:00

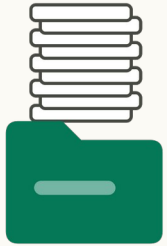
22:00

Written as it happened. Read under two laws.

23 Sep 2026 · Rb Noord-Holland

A court has already asked:
what did you do before it happened?

administrative law · no precedent



11 Sep 2026 — reporting

9 Dec 2026 — liability

11 Dec 2027 — CRA in full



Transparency upstream. Evidence downstream.

upstream · signals



collect · write · keep

10 years

William Janssen

CTO & HEAD OF ENGINEERING · AUTHOR OF A BOOK ON THE EU CYBER RESILIENCE ACT · BUILDING THE OPERATIONAL SIDE OF CRA COMPLIANCE · EX-RED HAT & FOUNDER